01 / LAB OVERVIEW

Spoof!

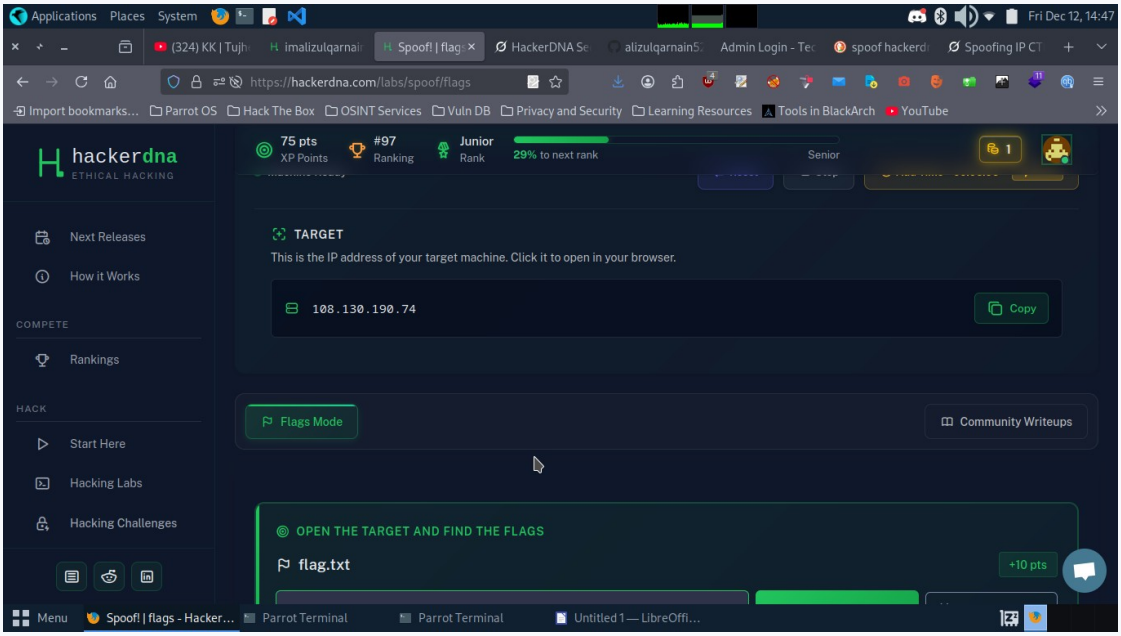
HackerDNA / Bypassing an IP-based web access restriction

English edition / Visual presentation: COMMANDO
A structured adaptation of the supplied walkthrough and its original screenshots.

Objective

Inspect a restricted web application, test its handling of the claimed client IP address, and retrieve a flag from the path disclosed after the restriction is bypassed.

Difficulty: Easy **Flags:** 1
Skills: Nmap, web reconnaissance, HTTP headers and access-control analysis.



01. Original HackerDNA lab dashboard.

Prepare the instance

Start the Spoof! lab and copy the current target IP. The source uses **108.130.190.74**; this is a historical instance address. Use your own instance’s values when following the steps.

Understand the technique

The attack forges an HTTP header that the application interprets as a client IP address. It does not change the network source address of the TCP connection.

02 / RECONNAISSANCE

Identify the restriction

Scan the host and inspect the HTTP service

```
nmap --open -Pn <TARGET_IP> -vv
```

The recorded scan identifies **80/TCP** as open. This establishes the web application as the next investigation target. The command above corrects the extra hyphen in the original prose.

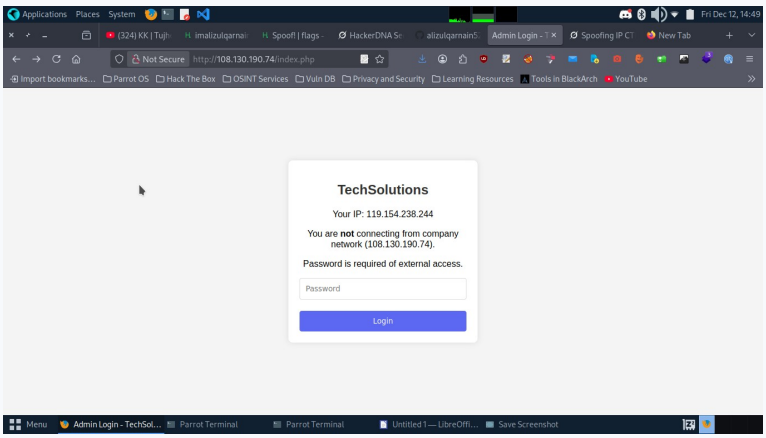
```
┌─[unknown@parrot]─[~]
└──╼ $nmap --open -Pn 108.130.190.74 -vv
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-12 14:24 EST
Initiating Parallel DNS resolution of 1 host. at 14:24
Completed Parallel DNS resolution of 1 host. at 14:24, 0.30s elapsed
Initiating Connect Scan at 14:24
Scanning ec2-108-130-190-74.eu-west-1.compute.amazonaws.com (108.130.190.74) [1000 ports]
Discovered open port 80/tcp on 108.130.190.74
Completed Connect Scan at 14:25, 16.56s elapsed (1000 total ports)
Nmap scan report for ec2-108-130-190-74.eu-west-1.compute.amazonaws.com (108.130.190.74)
Host is up, received user-set (0.17s latency).
Scanned at 2025-12-12 14:24:50 EST for 17s
Not shown: 999 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT   STATE SERVICE REASON
80/tcp open  http    syn-ack

Read data files from: /usr/bin/../share/nmap
Nmap done: 1 IP address (1 host up) scanned in 16.91 seconds
```

02. Original Nmap results showing the HTTP service.

Inspect the web page

Visit **http://<TARGET_IP>/index.php**. The TechSolutions portal displays the detected client address and says the request is outside the company network. It also reveals the address it expects for internal access.



03. External-access restriction and the expected company-network IP.

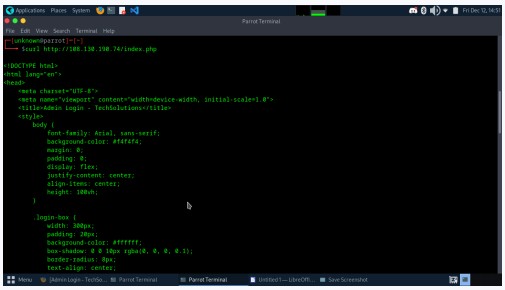
Record the company-network IP shown by your lab instance. Treat it separately from the target address, even though they match in this recorded run.

03 / HEADER MANIPULATION

Test X-Forwarded-For

Compare the ordinary request with a forged client-IP claim

```
curl "http://<TARGET_IP>/index.php"
```

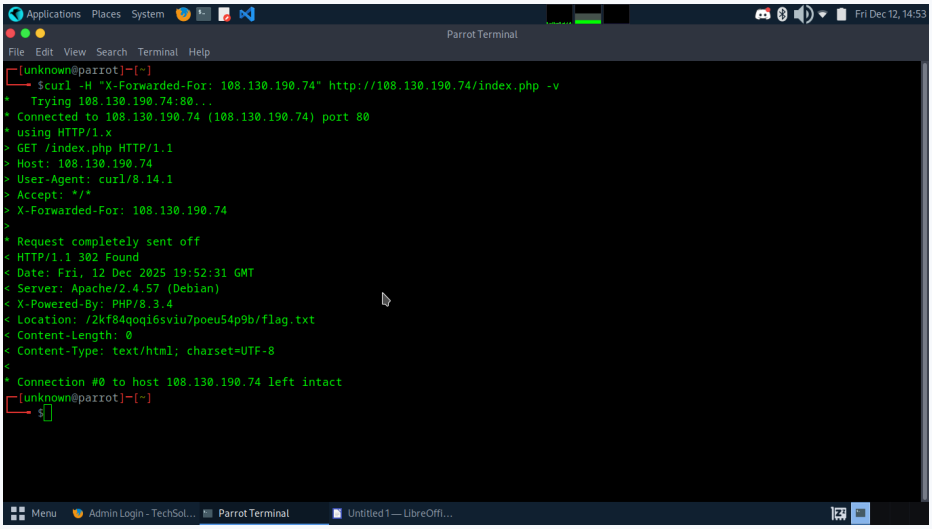


04. An ordinary request returns the login page HTML.

Send the claimed internal address

```
curl -v "http://<TARGET_IP>/index.php" \
  -H "X-Forwarded-For: <COMPANY_IP>"
```

The recorded request sets the header to **108.130.190.74**. The server responds with **HTTP/1.1 302 Found** and a **Location** header pointing to a nested path ending in flag.txt.



05. Successful request: forged header and redirect to the flag location.

The response change is the key evidence: an unverified, client-supplied header influences the application’s access decision.

04 / FLAG AND LESSONS

Follow the disclosed path

Use the exact Location value returned by the application

Retrieve the flag

Copy the full path from the **Location** response header. Do not assume the flag is directly at /flag.txt: the screenshot shows a generated directory before the filename.

```
curl "http://<TARGET_IP>/<PATH_FROM_LOCATION>" \
  -H "X-Forwarded-For: <COMPANY_IP>"
```

Here, <PATH_FROM_LOCATION> means the returned relative path without its leading slash. Retain the header if the destination also checks the claimed client address. Submit the returned flag in the lab dashboard.

Evidence boundary

The source describes successful retrieval and submission, but the supplied screenshots directly show the redirect rather than the final flag contents. No flag value is invented in this edition.

Why the bypass works

X-Forwarded-For can carry a client-address claim from a reverse proxy. If an application accepts the same claim directly from any requester, that requester can choose a value that satisfies a naive IP check.

Defensive lessons

Trust forwarding headers only from explicitly configured proxies. At the edge, discard or overwrite untrusted client-supplied forwarding values. Apply the same access controls to the destination resource and use authentication and authorization for sensitive content.

What this lab teaches

Scan the service, observe the restriction, identify the trusted input, compare responses, and follow the evidence. The important failure is misplaced trust in request metadata, not the secrecy of the flag path.

Edition note: English prose refined, five relevant source screenshots retained, and duplicate portal imagery omitted. Commands were not re-executed.